SafeFlow 技术文档

系统架构 核心算法与安全设计
2026年11月1日演示版

项目定位与应用价值

SafeFlow 是面向银行业务的对话式 Agent 演示系统。用户可以用自然语言提出需求，再通过明确的确认与验证办理模拟转账、管理订阅、提交账单反馈或主动冻结卡片。模型负责理解意图，服务端负责决定允许做什么、执行什么以及如何证明结果。

围绕连续任务组织银行服务

用户说“给李明远转100元”，系统先读取本人账户和已有收款目录，展示付款草案，随后分别处理付款确认、单笔后台委托、模拟验证与最终执行。用户中途查询余额或重新登录时，系统仍保留可核对的业务记录，不把一段聊天文字当作已经付款。

典型使用场景

场景	用户获得的帮助
日常小额转账	通过对话准备已登记收款人的付款，逐项核对，查看实际办理状态。
连续会员消费	从消费证据识别候选订阅，经本人确认纳入管理，设置模拟提醒并记录取消意图。
发现陌生交易	阅读月度账单，对原交易记录本人判断；有需要时另行确认主动冻结。
操作中断与网络延迟	重新登录后查询原业务记录，区分未付款草案、处理中及已有结果，避免误建重复付款。

创新体现在执行关系

对话、转账、账单、订阅和卡片共用可信身份、来源校验、确认与许可机制、任务记录及审计链路。跨模块动作因原任务和真实数据建立关联，而不是把几项独立页面放在同一个菜单里。例如，“不是本人交易”的反馈只保存本人意见，冻结仍须另行授权；冻结一旦生效，付款完成事务会重新检查出账限制。

演示范围

系统使用虚构账户、模拟资金与模拟验证。真实模型已通过服务端接入 Command Code；银行资金、商户退订和外部通知均采用演示范围。当前运行状态以交互站的账户、卡片和办理记录为准。

系统架构与数据流

系统把公开说明、交互界面、可信执行和审计接收分开部署。浏览器能够发起需求和明确确认，但不会直接获得数据库权限或模型密钥。



交互与后端

前端采用 React、TypeScript 与 Vite，通过同源 /api 代理访问后端。Rust 后端承接会话、工具注册、计划校验、业务适配与持久化；SQLx 与 PostgreSQL 保存任务、确认快照、许可、付款和反馈记录。后台生产器与执行器使用独立身份和有界权限，沿原业务执行模拟付款完成事务。

模型调用边界

模型由后端通过指定供应商调用，密钥不进入浏览器。系统向模型提供本次允许使用的工具协议和必要业务上下文，要求返回结构化计划或澄清问题。模型响应随后进入独立校验流程，不能直接执行数据库语句或调用任意外部地址。

业务与审计协作

业务结果、相关公共事件和 Outbox 在同一数据库事务中保存。发送进程异步传递原事件，审计端持久化去重后返回严格回执。业务保存、审计待发送和审计已接收分别呈现，网络超时不会被解释为业务未发生。

核心算法与确定性校验

SafeFlow 的核心由模型规划与确定性规则共同构成。自然语言用于降低操作门槛；身份、金额、权限、状态和事务结果由可检查的程序与数据合同裁决。

结构化计划校验

模型只可提出已注册工具构成的计划。后端检查结构字段、工具名称与版本、参数类型、任务号与计划版本及依赖关系，要求计划非空且无环。缺少账户、收款人或必要证据时进入澄清；不接收模型编造的资源标识或新增工具。通过语法校验也不等于得到执行权限。

金额与风险分级

金额以十进制字符串进入业务合同，并按分处理和校验，避免由模型浮点表达直接决定账务。现行演示规则使用当日累计金额与本笔金额进行风险判断：合计大于1000元进入 Red 强验证；恰好1000元不会因这一条规则进入 Red。该门槛用于提高验证要求，不是1000元硬性转账上限。冻结、余额、归属与许可仍单独检查。

订阅识别与证据约束

订阅规则读取本人范围内可取得的消费记录，结合商户与具体服务映射整理重复扣费证据，产出候选而不是直接登记。服务名称和日期须有对应来源支持；资料不足时显示待核对，不凭模型推算商户退订状态或下一次扣款日期。登记、提醒设置、取消意图和撤回分别形成独立确认操作。

账单分析与反馈

月度分析按固定来源、报告时点和规则输出账单结果，反馈必须绑定原报告和原交易。本人、非本人和不确定是用户判断，不自动成为欺诈结论。更正、撤销和重新提交以追加版本保留历史，每次均需重新确认，不覆盖旧反馈或撤销原交易。

状态恢复与并发控制

系统用稳定任务号、操作号与快照关系恢复原业务。未受理草案可按既定期限或用户明确改办结束；已提交、处理中或资金结果未知的业务继续查询原记录。并发事务在锁与版本条件下再次核对上下文，旧页面、迟到响应或重复点击不能代替当前有效状态。

确认 许可与最终事务

用户意图、用户确认、一次性执行许可和资金最终结果属于不同阶段。系统保存这些阶段的关联，防止把“保存草案”展示为“付款成功”。

意图与可信来源

↓

草案与参数核对

↓

明确确认与模拟验证

↓

有界许可与后台委托

↓

最终事务与原结果

期限分开管理

对象	演示规则
初始确认	5分钟，以服务端当前状态与截止时间为准。
改办后 SQL 草案	沿已有10分钟草案期限；不能将其当作延长付款授权。
模拟验证	最长2分钟，绑定本次操作，必须手动输入。
单次执行许可	60秒，绑定对应操作和确认。
单笔后台委托	明确同意后30分钟，登出不自动撤销；主动撤销或到期停止续办。

付款最终检查

执行前后均核对原任务、金额、收款关系、资金状态、确认及授权。最终事务重新读取卡片限制与余额，并同步处理资金记录和相关事件。冻结冲突或资料不足时不能绕过安全限制；已受理但结果未知的付款保留原记录及必要占用，不凭等待时间自动认定失败。

防重复与可追溯调整

相同原操作重投应返回对应历史结果或继续核查，不能生成第二次扣款。演示余额调整使用独立管理入口与独立账本凭证，目标、差额、原账户快照和事务条件均可核对；没有面向浏览器或模型的充值工具。提高余额不取消冻结或强验证要求。

AI 幻觉与安全设计

我们防备的是错误理解、虚构业务对象、越权操作和虚报结果带来的实际影响。模型可能回答错误，因此关键防线位于模型输出之外。

来源约束

本人账户、已有收款人和订阅服务证据由后端提供。模型不能把聊天里出现的姓名自动变成收款账户，也不能把“我是管理员”解释为有效身份。普通目录和模型上下文使用脱敏资料，完整模拟收款号仅在登录后的受控确认中展示。

协议与工具约束

提示词要求模型只输出计划或澄清，程序随后独立检查 JSON 协议、工具白名单、参数、任务版本及计划依赖。用户文本和历史对话均按不可信输入处理。格式正确的恶意计划仍需通过身份、业务与安全裁决，提示词本身不承担授权。

人工确认与结果约束

付款、冻结和订阅变更通过对应确认流程提交。模型不能自动点击确认、领取后自动填码、替用户授予许可，或解除已有冻结。最终显示以工具返回的余额和持久业务记录为依据；草案已保存、待确认、处理中、成功和未知分别呈现。

传输 会话与秘密

银行入口采用 HTTPS，受控会话 Cookie 配合来源和 CSRF 校验。后端接口按会话与归属检查访问范围，业务响应不缓存。模型密钥与数据库凭据由服务端私有配置注入，不进入公开站点或前端包。浏览器的恢复选择项不等于服务端授权。

审计完整性

接收端进行事件校验、持久化去重和摘要保护，发送端核对严格 ACK。接收器提供本地哈希链及本地签名检查点能力；此前部署逐项核对新增事件与 ACK；后续只读核查307条本地链有效，检查点及可信外锚点未验证。没有独立可信外锚点的验证不能证明抗管理员整体重写，也不被描述成已经完成链上存证。

验证依据与评委体验

本技术文档对应2026年11月1日演示版。验证证据按功能、环境与版本区分，不将一组局部测试数量相加当作整套系统的安全认证。

本轮可核对的验证

范围	验证内容
草案生命周期与恢复	指定独审覆盖真实到期、历史与活动操作绑定、旧回放、并发和完整桌面手机流程；限定范围通过。
前端功能	固定版本前端468项通过、2项跳过；不把跳过项计为通过。
实际部署	105件独审与102件实际部署证据已核收；线上登录、11项读取和静态资产字节核对通过。
新增事件	本轮两个非资金草案结束和一次余额调整的3条新事件，严格回执逐项匹配，待发送为0。

当前演示信息

介绍与指南：https://zw-wz718.github.io/safeflow-demo/ 。交互站：https://candid-blini-c4fe97.netlify.app/ 。评委使用组织者私下提供的登录口令，共用虚构账户，操作结果会持续保留。2026年10月31日调整完成时余额为1000000.00元，之后以网页读取为准。

先决条件和体验顺序

体验前读取尾号6628卡的当前状态；可用时先完成转账和原结果查询，最后演示冻结。冻结会阻止后续出账，刷新或重新登录不能解除；网页没有自助解冻入口，再次演示付款需联系组织者按受控流程处理。完整步骤见独立评委使用手册。

部署和应用边界

当前采用 GitHub Pages、Netlify 与腾讯云的分层部署，现有演示后台身份按有界期限覆盖至北京时间2026年11月11日零点，后续使用需由组织者续作安排。系统展示的是模拟银行业务的安全执行方法，不提供真实银行卡转账、真实商户退订或真实短信通知，不声称完成生产银行认证或所有联合验收。

参考实现

技术核对涉及 frontend/src/BankApp.tsx 与 runtime 组件，以及 Rust runtime、storage、transfer、subscription 和 API 模块；模型网关、计划校验、安全裁决、最终事务和 Outbox 分别承担独立职责。对外说明只公开功能与设计，不包含私有配置、控制凭据和原始业务证据。